

Social engineering in the context of ensuring information security

Natalia Mamedova^{1,*}, Arkadiy Urintsov¹, Olga Staroverova¹, Evgeniy Ivanov¹ and Dmitriy Galahov¹

¹Plekhanov Russian University of Economics, 36, Stremyanny lane, 117997, Moscow, Russia.

Abstract. The paper presents the main key features of social engineering and a social engineer activity. Emphasis is placed on the study of social engineering techniques in the system of human-machine interaction used to implement the illegal (malicious) manipulation of human behavior patterns. The matrix of social engineering qualification criteria and the map of information security risks caused by social engineer actions were built.

1 Introduction

The practice of human-machine interaction (HMI) makes increasingly high demands on the level of information security. This process is like an eternal dispute - what is stronger, a sword or a shield. The evolution of information protection methods reflects the evolution of unauthorized data access methods [1].

Nowadays people are actively embedding computers in their environment; they are trying to make the computer more "human", the level of computer dependence on the outside world also increases with the development of networks [2, 3]. On the other hand, the human factor continues to be the least controlled element of HMI [4], which, in turn, according to the modern information and communication technologies development creates not only new opportunities, but also new risks [5]. As a result, the number of information security [6] vulnerability factors increases.

Someday, a computer will learn how to evaluate human behavior [7,8] and make decisions based on the results of cognitive processes analysis, considering the value and semantic aspects of personality behavior. Consequently, we are waiting for a new evolutionary leap in the confrontation of "sword and shield". But, so long as a person is only understandable by the other person, the social engineering knowledge will be in demand [9].

2 Introduction to the problem

A review of research papers on the research topic showed that the theoretical, methodological and applied aspects of the problem of social engineering evolved in a certain way.

First, it should be recognized that the attitude towards the threat of social engineering has radically changed. Previously, there was a trend of systematically increasing the protective and preventive potential of

corporate IT systems. This trend was a response to a threat or breach of information security.

Therefore, remedies were actively developed, as well as means to prevent attacks and minimize the consequences of the social engineer actions. Scientists generalized the trajectory of social engineering and classified actions of the social engineer. Thus, requirements for data transfer protocols and information security policy [Abraham, S; Mills, D], profile settings [Alim, S], software development and information systems architecture [Penserini, L] were formed. The social nature of information security threats is being actively studied [Dalpiaz, F], and means are proposed against the influence of the human factor [Luo, X], Pritchard, M]. As result, training programs, procedures and policies were formed. Approaches to testing information systems [Pavkovic, N; Sandouka, H] and testing methodology [Dimkov, T] have been developed. As a result, various protection strategies [Gonzalez, J], user guides and practical scenarios [Jansson, K; Kamphan, P.] were developed. Social engineering was considered as a fraudulent "low-tech" approach to the high-tech world of the Internet [Manske, K]. According to it, the social engineer exploited the vulnerabilities of the Internet environment, but human ethics and personality psychology were as before pressure points.

However, this approach has evolved along with the evolution of the high-tech world of the Internet. On the one hand, the taxonomy of social engineering, as the practice of systematization of a complex system, remains the same - it still is and is perceived as a type of fraud. Three taxonomies are often used in literature: Cialdini's principles of influence, Gragg's psychological triggers, and Stajano's principles of scams [Ferreira, A.].

Thus, we are now dealing with high-tech fraud, which is taking global forms. The social engineer manipulates the patterns of thinking in the digital environment, using data on the results of online interaction between users and group behavior, including cultural values

*Corresponding author: rector@rea.ru

[Karamanian, A]. Methods of protection from social engineering also become global. An example is the use of machine learning to detect attacks in the results of natural language processing to identify questions, commands, dialogs [Sawa, Y]. The effectiveness of the use of artificial intelligence to protect against social engineering depends on the work on the knowledge bases of cybersecurity in human capital, prototyping risks, environmental structuring [Aldawood, H].

It should also be noted that protection methods become gradient depending on the level and limit of attack [Kaushalya, S]. Modern protection methods are aimed at point and dosed counteraction [Fathollahi-Fard, A.] and characterize the tendency to save effort and meaningful actions to counteract social engineering. This tendency develops up to the acceptance as a variant of the norm and the justification of social engineering within reasonable limits. Manipulations of lower categories in the hierarchy of social communities can be justified if they are understood as part of an individual obligation to participate in the community [Hatfield, J.].

Research on the social nature of social engineering has also evolved. If previously the personal qualities of the object (the victim) were put at the forefront in assessing the human factor, now the factor of openness of personal data is key when evaluating such social engineering methods as persuasion, fabrication and data collection [Tetri, P.]. Denoting data openness as a vulnerability, scientists complement it by pointing out the risks of networking, citing social networks as an example [Algarni, A.]. Spreading and infecting a botnet poses a threat to both users and the social network as a whole [Li, S.]. Thus, the object of social engineering is no longer a specific user, but the users of the entire social network.

Phishing technologies have also evolved [Bhakta, R.; Krombholz, K; Gupta, S.]. This was facilitated by the development of collaboration formats (BYOD - bring your own device), which creates prerequisites for attacks such as phishing, and a variety of communication tools, which increases the risks of network attacks, in particular, the creation fake versions of existing web pages or phishing emails.

3 Models and methods

Social engineering is a set of approaches of applied social sciences, or applied sociology, focused on purposeful change of organizational structures that determine human behavior and provide control over it [1].

Social engineering is closely related to the field of human-machine interaction psychology [10, 11]. The positive aspect of the applied nature of social engineering is to increase the effectiveness of the control function in the human-machine interaction system. The result of the control function is commonly understood as an increase in labor productivity and computer performance. The negative aspect is the use of social engineering techniques to manipulate the patterns of human behavior and obtain the result by:

- fraud (fraud, breach of trust);
- crimes in the field of information technologies;
- dissemination of unlawful information;
- malicious interference through computer networks in the work of various systems.

As a result, access to information that is protected, confidential and closed will be considered.

We specifically operate with criminal law¹ categories in order to emphasize the unlawful (harmful) nature of the social engineer actions [12]. The question arises: is it right to call a subject a social engineer, who is using social engineering techniques for his own benefit consciously and with understanding of the wrongfulness of his actions? After all, not every social engineer uses techniques to influence human behavior in this way. It may be appropriate to use other semantically close concepts associated with a breach of information security - a hacker or an information intelligence agent. However, by prioritizing the used techniques of social engineering and perceiving human-machine interaction as a conditional environment, in relation to (and not inside) which the subject carries out his actions, we identify this person as a social engineer.

The key features of a social engineer, regardless of the nature of his actions, are: conscious behavior, active mode of action, purposeful influence [11]. The area of impact is the human-machine interaction environment on which the social engineer makes organizational changes. Such changes are not carried out independently, but through the establishment of behavioral control over objects - a person, people, using their involvement in the environment of human-machine interaction. The object can be the information owner, the information producer, the user (consumer) or the information holder.

All the above describes an abstract category "social engineer". The establishment of the unlawful (malicious) nature and consequences of the activity is possible through determining the target setting of the social engineer actions [13, 14]. In other words, determining why (for what purpose) a social engineer performs such actions, we will establish their character.

4 Results and discussion

Achieving the goals is determined by the method of access to the information when methods of human-machine interaction interested the social engineer directly or in connection with the person (persons), interacting with them. If the method of information access violates the status of protected, confidential, confidential information, the actions of the social engineer should be considered as unlawful.

¹ Resolution of the Plenum of the Supreme Court of the Russian Federation of 30.11.2017 No. 48 "On judicial practice in cases of fraud, embezzlement and embezzlement"; "Guidelines for the implementation of prosecutorial supervision over the execution of laws in the investigation of crimes in the field of computer information" (approved by the Prosecutor General's Office of Russia)

* Corresponding author: rector@rea.ru

We focus our attention on one provocative moment. If, as a result of applying methods of influence, a social engineer has gained access to confidential information, the analogue of which is publicly available, but using manipulating models of human behavior and is caused damage, his actions are illegal. However, if the damage did not cause, the actions of the social engineer do not violate the law, although it blame for non-compliance with ethics [15]. In a situation where a social engineer obtained (or made an attempt to obtain) access to

confidential information, even without using it and not causing damage by his actions, the actions are unlawful due to the impact applied to the object [16].

To illustrate the qualifying attributes of social engineering, a matrix was drawn up by which it can be established in which combinations the actions of the social engineer are unlawful (harmful) in nature (Table 1). Filling out the table, we proceeded from the established fact of the impact on the object through the techniques of social engineering.

Table 1. Matrix of qualifying attributes of social engineering.

	Status "protected information": yes	Status "protected information": no	Status "access granted": yes	Status "access granted": no	The fact of "damage when gaining access": yes	The fact of "damage when gaining access": no	Status "information used": yes	Status "information used": no	The fact of "damage caused by using": yes	The fact of "damage caused by using": no
Status "protected information": yes	+		+	+	+	+	+	-	+	-
Status "protected information": no		-	-	-	+	-	+	-	+	-
Status "access granted": yes	+	-	+		+	+	+	-	+	-
Status "access granted": no	+	-		-	+	-				
The fact of "damage when gaining access": yes	+	+	+	+	+		+	-	+	-
The fact of "damage when gaining access": no	+	-	+	-		-				
Status "information used": yes	+	+	+		+	+	+		+	+
Status "information used": no	-	-	-		-	-		-		
The fact of "damage caused by using": yes	+	+	+		+		+		+	
The fact of "damage caused by using": no	-	-	-		-		+		-	-

The results of qualification signs comparison showed that the most significant signs are the status of the information and the damage caused on accessing the information.

To assess the impact effect of social engineers on the object the risk map was compiled. Table 2 presents the identified information security risks according to the

results of the constructed scenario of a risk situation. The risk situation was modelled by determining the causal relationship between the actions of the social engineer and the response of a normally functioning security system in the organization. The identified risks are consolidated by stages of social engineering. Scenarios for the occurrence of a risk situation are ranked in

* Corresponding author: rector@rea.ru

qualitative terms of “probability” and “impact” on the risk object dispersed in an ascending order.

Table 2. Distribution of information security risks from social engineer actions.

Name of the social engineering stage	Social engineer action	Ranking code
Preparatory stage	object data collection	A
	introduction to the area of the facility	B
	request for feedback from the object	C
	imposing actions on an object	D
Stage of access to the information	hacking devices	E
	object action programming	F
	provocation	G
Stage of using received information	commercialization of the information received	H
	distribution of malicious content	I
	interference with systems, devices	J
	dissemination of illegal information	K

Placing risks on the map (Figure 1) in accordance with the parameters of “probability” and “impact” is the final step of building a risk map and, at the same time, the starting point for the beginning of the operational risk management process.

As the risk map shows, the greatest threat to information security is created by the actions of a social engineer, activating the human factor and associated with the active actions of an object that has fallen under the influence of a social engineer. Above all at zone of risk is the protection of information access, the owner (holder) of which is the object of manipulation itself. If there is an element between the social engineer and data access where the human factor is minimized, then such risk situations are shown on the map below the risk tolerance limit. Such an element can be an authorized access system, a system of distributed access rights, a storage system, data updates, a data coding system, and so on. With respect to such risks, the information security system provides for the operation of algorithms that limit the capabilities of the social engineer or the effect of its impact. Although for this group of risks, the influence of the human factor should be taken into account.

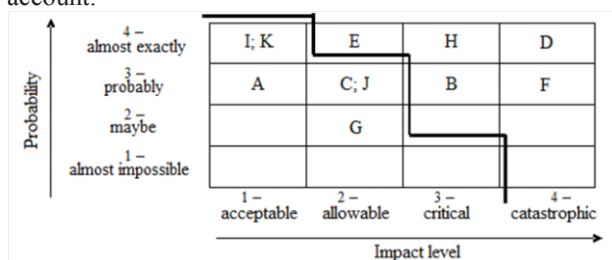


Fig. 1. Map of information security risk from the actions of a social engineer.

By correcting the risk map fields due to changes in the initial data and practices of a particular organization, it is possible to increase the steadiness of the information security system to social engineering techniques.

Conclusion

The given results fit into the logic of the modern approach to social engineering and its global distribution - they are beyond the scope of management of corporate risk caused by the social engineer actions and the impact assessment on the psychology of the individual. It has been possible by shifting the focus from the object of social engineering to the subject - directly to the social engineer and the harmful nature of his actions. Consequently, the proposed solutions can be applied for assessing the threat of social engineering in the context of the vulnerability of the human factor, but without reference to a specific technology of social engineering.

The research was supported by grant of the President of the Russian Federation according to state support of leading scientific schools (grant № NSh-5449.2018.6).

References

1. T. Bierschenk, *From the anthropology of development to the anthropology of global social engineering*, Zeitschrift fur Ethnologie, Review vol. 139, no. 1, 73-98, (2014)
2. S. Abraham and I. Chengalur-Smith, *An overview of social engineering malware: Trends, tactics, and implications*, Technology in Society, Article vol. 32, no. 3, 183-196, (2010), doi: 10.1016/j.techsoc.2010.07.001
3. D. Mills, *Analysis of a social engineering threat to information security exacerbated by vulnerabilities exposed through the inherent nature of social networking websites*, Proceedings of the 2009 Information Security Curriculum Development Annual Conference, InfoSecCD'09, 139-141, (2009), doi: 10.1145/1940976.1941003
4. X. Luo, R. Brody, A. Seazzu, and S. Burd, *Social engineering: The neglected human factor for information security management*, Information Resources Management Journal, Article vol. 24, no. 3, 1-8, (2011), doi: 10.4018/irmj.2011070101
5. I.V. Pavlekovskaya, O.V. Staroverova, A.I. Urintsov, *The impact of scientific and technological progress on the development of the information society*, ed: Bulletin of Economic Security, no 3, 212-217, (2017)
6. S. A. D. T. P. Kaushalya, R. M. R. S. B. Randeniya, and A. D. S. Liyanage, *An Overview of Social Engineering in the Context of Information Security*, in 2018 IEEE 5th International Conference on Engineering Technologies and Applied Sciences, ICETAS 2018, (2019), doi: 10.1109/ICETAS.2018.8629126

* Corresponding author: rector@rea.ru

7. A. M. Fathollahi-Fard, M. Hajiaghahi-Keshteli, and R. Tavakkoli-Moghaddam, *The Social Engineering Optimizer (SEO)*, Engineering Applications of Artificial Intelligence, Article vol. **72**, 267-293, (2018), doi: 10.1016/j.engappai.2018.04.009
8. L. Penserini, M. Kolp, and L. Spalazzi, *Social-oriented engineering of intelligent software*, Web Intelligence and Agent Systems, Article vol. **5**, no. 1, 69-87, (2007)
9. K. Jansson and R. Von Solms, *Social engineering: Towards a holistic solution*, Proceedings of the South African Information Security Multi-Conference, *SAISMC*, 23-34, (2010)
10. N. Pavković and L. Perković, *Social Engineering Toolkit A systematic approach to social engineering*, MIPRO 2011 - 34th International Convention on Information and Communication Technology, Electronics and Microelectronics - Proceedings. 1485-1489, (2011)
11. K. Manske, *An introduction to social engineering*, Information Systems Security, Article vol. **9**, no. 5, 1-7, (2000), doi: 10.1201/1086/43312.9.5.20001112/31378.10
12. J. J. Gonzalez, J. M. Sarriegi, and A. Gurrutxaga. *A framework for conceptualizing social engineering attacks*, vol. **4347** LNCS, 79-90, (2006)
13. F. Dalpiaz, *Social threats and the new challenges for Requirements Engineering*, 1st International Workshop on Requirements Engineering for Social Computing, RESC'11, 22-25, (2011), doi: 10.1109/RESC.2011.6046716
14. K. Krombholz, H. Hobel, M. Huber, and E. Weippl, *Advanced social engineering attacks*, Journal of Information Security and Applications, Article vol. **22**, 113-122, (2015), doi: 10.1016/j.jisa.2014.09.005
15. J. M. Hatfield, *Virtuous human hacking: The ethics of social engineering in penetration-testing*, Computers and Security, Article vol. **83**, 354-366, (2019), doi: 10.1016/j.cose.2019.02.012
16. A. Khlobystova, M. Abramov, and A. Tulupyev. *An approach to estimating of criticality of social engineering attacks traces*, Studies in Systems, Decision and Control, vol. **199**, 446-456, (2019)

*Corresponding author: rector@rea.ru